Skybirds Website: Issues Report

Covers the user website, admin panel and API (`skybird-user-frontend`, `skybird-admin`, `skybird-api`) · First review 28 October 2026 · Updated 29 October 2026

This report lists everything found in a code audit of all three apps and a hands-on walk-through of every page in a browser, on desktop (1280px) and mobile (390px). Each issue has an ID, where it is in the code, what goes wrong, and a suggested fix.

10	21	14	5	3
Critical: breaks for users or the business	Backend issues	Functional & navigation	Visual / UI	Minor / clean-up

What changed in this update (29 October 2026)

- NEW **18 new issues** from a second line-by-line review of the code: C8, C9, C10, B11, B12, B13, B14, B15, B16, B17, B18, B19, B20, B21, F12, F13, F14, V5.
- UPDATED **9 existing entries corrected or extended**: C1, C4, C6, B3, B10, F3, F6, F11, M3. The changed wording starts with “Update:” or replaces the old description.
- The recommended fix order below now includes the new items.

Recommended fix order

1. **C2:** confirm where the live API runs and whether lesson videos survive restarts. This is the most likely reason videos don't play.
2. **C1:** keep lessons playing past 5 minutes (including on Safari/iPhone).
3. **C4:** remove the default admin password from the login page, and change it if it still works.
4. **C3, C8:** make sure every paying student gets access (Razorpay webhook + payment records).
5. **C9:** stop the admin panel from discarding uploaded videos.
6. **C6, C10, B1:** set `TRUST_PROXY=true`, fix the OTP and API limits, and lock down CORS.
7. **F1–F3, F12:** fix the login/session problems.
8. **C5, B11, B13:** uploads.
9. Then the rest of the backend, visual and minor items.

1. Critical issues

ID	Issue	Where	What goes wrong / Fix
C1	**Lessons stop playing after about 5 minutes** UPDATED CRITICAL	`skybird-api/services/playbackService.js:10` `controllers/videoController.js:55-67` `user-frontend/src/components/ProtectedVideo.jsx`	The playback token expires after 300 s and the player never asks for a new one, so every video segment after that is refused. Lessons run up to about 13 min. **Update:** on Safari and iPhone the player uses the browser's own HLS support (`video.src`, ProtectedVideo.jsx:56), which has no 410 handling at all, so the fix must cover that path too. The token is in the video URL, so a longer TTL also means a copied URL keeps working for longer. **Fix:** when the player gets a 410 error, fetch a new token and resume at the same second (both hls.js and the Safari path). Short term: set `PLAYBACK_TOKEN_TTL_SECONDS` to 1800 or more.
C2	**Lesson videos missing on the server** CRITICAL	`skybird-api/private-videos/hls/` `user-frontend/src/api/axios.js:4-6`	The live database lists 11 lessons, but 10 of their video folders don't exist on the audited machine. The code says the API runs on Render's free tier, whose disk is wiped on every redeploy or restart. When that happens, all lessons return "Video not found". **Fix:** attach a persistent disk and point `VIDEO_STORAGE_PATH` at it, or move videos to S3/R2 or a video service. Re-upload any missing lessons.
C3	**A student can pay and not get the course** CRITICAL	`skybird-api/controllers/paymentController.js:141` `user-frontend/src/components/PaymentModal.jsx:112`	Access is granted only if the browser calls `/payment/razorpay/verify` after paying. If the tab closes or the network drops, the money is taken and no access is given. There is no Razorpay webhook and no record of payments. **Fix:** add a signed Razorpay webhook (`order.paid`) that runs the same grant logic, and store each payment in a `Payment` collection.
C4	**Admin login shows the default password** UPDATED CRITICAL	`skybird-admin/src/pages/Login.jsx:8, 89` `skybird-api/controllers/authController.js:345`	The form comes pre-filled with `admin123` and shows "Default: admin@example.com / admin123" to everyone. The server-side block is commented out. If that account exists, anyone can take over the site. **Update:** `seed.js:298` refuses `admin123`, so the account exists only if it was created another way. Still try it on the live site. (Screenshot in section 5.) **Fix:** remove the pre-fill and the hint, and change any admin password that is still `admin123`.
C5	**Long video uploads time out** HIGH	`skybird-api/controllers/adminController.js:57` `services/videoService.js:36`	The upload request waits while ffmpeg converts the whole video, which takes minutes. The browser or proxy gives up after about 60 s and the admin sees "failed". Conversion keeps running and leaves an orphan video folder, and the admin uploads again. **Fix:** return the videoId immediately, convert in the background (one at a time), and let the admin panel poll for "processing / ready / failed".

ID	Issue	Where	What goes wrong / Fix
C6	**OTP limit shared by the whole site behind a proxy** UPDATED HIGH	`skybird-api/middleware/rateLimit.js:5` `server.js:33, 67-81`	With `TRUST_PROXY=false` behind Render/Nginx/Cloudflare, every visitor appears as the same IP. The whole site then gets only 3 OTPs per 15 minutes. There is also no limit per phone number, so someone can run up your SMS bill by requesting OTPs for many numbers. **Update:** the limiter key includes the request path, so the "300 requests per 15 min" API limit counts each URL separately rather than each visitor. In practice there is no overall limit. **Fix:** set `TRUST_PROXY=true`, allow at most one OTP per number per 60 s, and key the general API limit on the visitor only, not the path.
C7	**Wrong video folder in .env** FIXED	`skybird-api/.env:26`	A stray backtick (`./private-videos`) made the API read videos from an empty folder. Fixed during the first review; the API must be restarted to pick it up. **Fix:** done. Restart the API.
C8	**Payment taken but not yet "captured" gives no access** NEW HIGH	`skybird-api/controllers/paymentController.js:236-246`	Verify accepts a payment only when its status is `captured`. If Razorpay auto-capture is off or delayed, the payment is still `authorized` when the student returns, so they pay and get no access. This is a second way to hit C3. **Fix:** accept `authorized` and capture it from the server, or rely on the C3 webhook (`payment.captured` / `order.paid`) to grant access.
C9	**Admin "main course video" upload is thrown away** NEW HIGH	`skybird-admin/src/pages/CourseForm.jsx:235, 406` `skybird-api/controllers/adminController.js:280`	The course form uploads a main video, shows "Video processed successfully" and sends its `videoId` on save. The API never saves it: `videoId` is not in the allowed fields or in the Course schema. The video is lost and its folder is left on disk. **Fix:** remove the main-video upload from the form (lessons already cover it), or add it to the schema and the allowed fields.
C10	**Testimonial videos blocked on the live HTTPS site** NEW HIGH	`skybird-api/controllers/testimonialController.js:12, 28`	Testimonial video URLs are built from `req.protocol`. Behind Render's proxy without `TRUST_PROXY` that gives `http://` links, which browsers block on an HTTPS page, so the home-page testimonials don't play. **Fix:** set `TRUST_PROXY=true` (also needed for C6), or return a relative path like `/api/testimonials/<id>/master.m3u8` and let the frontend add the API address.

2. Backend issues (API)

ID	Issue	Where	What goes wrong / Fix
B1	CORS lets every website call the API HIGH	`skybird-api/server.js:48` `.env CLIENT_URL`	`|| origin` allows any site, so the allow-list does nothing. Also, `CLIENT_URL` ends with "/", which never matches a browser origin, so the live site would be blocked once the bug is fixed. **Fix:** remove `|| origin` and list the exact origins without a trailing slash (main site, www, admin).
B2	Coupon usage limits can be exceeded MEDIUM	`services/couponService.js:75-83` `paymentController.js:291-300`	The limit is checked when checkout starts, but uses are counted only after payment. Fifty people can all use a "first 10 buyers" coupon. **Fix:** reserve the use at order creation with a conditional update (`usedCount < usageLimit`).
B3	Deleted lessons keep their video files forever UPDATED MEDIUM	`controllers/adminController.js:447-476`	Only testimonials delete their video folder, so the disk slowly fills with unused videos. Replacing a lesson's video in the admin panel leaves the old folder behind too. **Fix:** when a lesson is removed or replaced, delete its folder if no other course or testimonial uses it.
B4	Deleting a customer erases their purchase history MEDIUM	`controllers/adminController.js:553`	Purchases live only inside the user record. Deleting a customer leaves no record for refunds or disputes. **Fix:** the `Payment` collection from C3 keeps them; consider blocking customers instead of deleting them.
B5	No automated tests MEDIUM	`whole repo`	Payment verification and video access checks have no tests. A small change could give courses away or lock out paying students. **Fix:** add `node:test` + supertest tests for verify (bad signature, wrong user, success once) and playback (non-owner gets 403).
B6	Admin dashboard loads every user LOW	`controllers/adminController.js:585`	The purchase count loads every user into memory, which gets slower as users grow. **Fix:** count with a MongoDB aggregate using `$size`.
B7	Upload limit silently capped at 2 GB LOW	`middleware/upload.js:39`	`.env` says 10 GB, but the code caps uploads at 2 GB, so a 3 GB upload fails with a confusing error. **Fix:** set `.env` to the real limit.
B8	If Cloudinary fails, thumbnails are stored inside the course LOW	`controllers/adminController.js:34-41`	If Cloudinary fails, an image of up to 8 MB is saved as text in the course record and sent to every visitor. **Fix:** return an error instead.

B9	Dead code and unused packages
	LOW
		`package.json`
		`customerController.js:24`
		`courseController.js:144`
		`testimonialController.js:123`
			`express-validator` is unused; `uuid` can be replaced by `crypto.randomUUID()`; the disabled `/customer/purchase` and `/courses/:id/stream` endpoints; the missing `salePrice` field; a no-op replace.
			Fix: delete them (about 60 lines and 2 dependencies).

ID	Issue	Where	What goes wrong / Fix
B10	Secrets and docs UPDATED MEDIUM	`skybird-api/.env` `README.md`	Live payment, database, cloud and SMS keys sit in plain text in `.env`. If this folder was ever zipped or shared, change all of them. The README describes Twilio, but the code uses APITxT. The README also says to copy `.env.example`, which doesn't exist in the repo. **Fix:** rotate the keys if they were shared; update the README; add a `.env.example` with no real values.
B11	File-upload library has known security flaws NEW MEDIUM	`skybird-api/package.json` `package-lock.json (multer 1.4.5-lts.2)`	`multer` 1.4.5-lts.2 has published denial-of-service flaws (CVE-2025-47935, CVE-2025-47944 and later ones) where a malformed upload can leak memory or crash the API. Uploads are admin-only, so the exposure is limited. **Fix:** upgrade to `multer` 2.x and re-test the course, thumbnail and testimonial uploads.
B12	100% coupons and free courses can't be used NEW MEDIUM	`controllers/paymentController.js:94` `models/Course.js (price min 0)`	A final amount of ₹0 is rejected as "Invalid payable amount". The admin panel still lets you create a 100% coupon or a ₹0 course, but no student can ever redeem or unlock it. **Fix:** when the amount is 0, grant access directly (no Razorpay order); otherwise block 100% coupons and ₹0 prices in the admin panel.

B13	Thumbnail uploads are loosely checked and lost on redeploy NEW MEDIUM	`routes/admin.js:82-97`
		`middleware/upload.js:19, 39`
		`.gitignore`
			The `thumbnail` field on course create/update accepts video files up to 2 GB. Files go to `uploads/thumbnails` on the same temporary disk as C2, so they vanish on redeploy. `uploads/` is also not in `.gitignore`, so local thumbnails can be committed.
			Fix: accept only images up to 8 MB on that field, store thumbnails in Cloudinary (already used elsewhere), and ignore `uploads/`.

B14	Resetting a password doesn't log out other sessions NEW MEDIUM	`controllers/authController.js:303-335` `authController.js:13 (7-day tokens)`	Login tokens last 7 days and can't be revoked. If someone else is logged in to a student's account, a password reset doesn't sign them out. **Fix:** store a `passwordChangedAt` (or token version) on the user and reject tokens issued before it.
B15	OTP endpoint reveals which numbers are registered NEW LOW	`controllers/authController.js:134-141`	Sending a number to `send-otp` answers whether it has an account ("existingUser" or "No account found"). Anyone can check lists of numbers. **Fix:** accept as a known trade-off of the login design, or keep the per-number limit from C6 tight to slow it down.
B16	Login token accepted from the URL NEW LOW	`controllers/courseController.js:19-21`	The playback-authorization endpoint also reads the main 7-day login token from `?token=`. Tokens in URLs end up in server and proxy logs. **Fix:** accept the login token only from the `Authorization` header.

ID	Issue	Where	What goes wrong / Fix
B17	**Database queries accept operator objects** NEW LOW	`controllers/courseController.js:44-45` `paymentController.js:42, 210`	Query and body values go straight into MongoDB filters, so `?level[$ne]=x` or an object as `courseId` is treated as a query operator. Impact today is small (public course data only). **Fix:** turn on Mongoose `sanitizeFilter`, or convert these values to strings before querying.
B18	**A failed video file read can crash the API** NEW LOW	`controllers/videoController.js:66, 79` `testimonialController.js:107`	Segments and keys are streamed with `createReadStream().pipe(res)` and no error handler. If a file disappears or can't be read mid-request, the unhandled error stops the whole API process. **Fix:** use `stream.pipeline` or add an `error` handler that ends the response.
B19	**Course update can wipe all lessons** NEW LOW	`controllers/adminController.js:290-304`	If a course update is sent as a file upload with a video but without the `videos` list, the existing lessons are replaced by the single new one. The admin panel doesn't send that request today, so this is latent. **Fix:** start from the course's current lessons when no list is sent, or remove video upload from this endpoint.
B20	**Coupon edits skip validation** NEW LOW	`controllers/couponAdminController.js:190-273`	Editing a coupon doesn't re-check that the value is above 0, and switching a large fixed discount to "percentage" isn't checked against the 100% cap. A duplicate code fails with a generic error. **Fix:** run the same checks as create, and return a clear message for a duplicate code.
B21	**Video playlist describes the stream wrongly** NEW LOW	`services/videoService.js:66, 85-88`	The master playlist always says 1280×720 even for smaller videos, and its codec string (`avc1.4d401f`, level 3.1) doesn't match the `-level 4.0` encode. Most players ignore this, but strict ones (some smart TVs and older iPhones) may refuse the stream. **Fix:** write the real resolution and the matching codec string (`avc1.4d4028`), or encode at level 3.1.

3. Functional & navigation issues (frontend)

ID	Issue	Where	What goes wrong / Fix
F1	**An expired session still looks logged in** HIGH	`user-frontend/src/api/axios.js:20`	On a 401 the token is removed from storage but not from the app state. Reproduced: the navbar still showed the name and Logout while every API call failed. **Fix:** on 401, call `logout()` from UserContext and redirect to `/login`.
F2	**Expired session tells paying students they own nothing** HIGH	`user-frontend/src/pages/Dashboard.jsx`	The dashboard shows "Owned courses 0. No courses yet, buy a course" instead of "please log in again". (Screenshot in section 5.) **Fix:** handled by F1; also show an error state when loading purchases fails.

ID	Issue	Where	What goes wrong / Fix
F3	**Login doesn't return you to where you were** UPDATED MEDIUM	`user-frontend/src/pages/Login.jsx:41, 113, 134`	A student who clicks "Buy" and logs in is sent back to the course for a moment, then moved on to `/courses` or `/dashboard` by `navigate(res.redirectTo)`, so the course page flashes and disappears. **Fix:** `navigate(from || res.redirectTo)`.
F4	**Video player reads the API address differently** MEDIUM	`ProtectedVideo.jsx:6` `skybird-user-frontend/.env`	The player reads `VITE_API_URL` with no fallback, while the rest of the site falls back to the Render address. If it's missing, courses load but videos fail. `.env` points to localhost. **Fix:** use `API.defaults.baseURL`; add `.env.production`.
F5	**`/payment/success` is a fake page** MEDIUM	`user-frontend/src/pages/PaymentSuccess.jsx:8, 31, 42`	Anyone who opens it sees "Course Unlocked!", a made-up transaction ID and "verified through PayU", but payments use Razorpay. Nothing links to it. **Fix:** delete the page (and `/payment/failure`), or show real data from the order.
F6	**Bad lesson link shows an error** UPDATED LOW	`user-frontend/src/pages/Watch.jsx:127-132`	`/watch/…?v=<wrong id>` shows "No video available" instead of opening the first lesson. **Fix:** fall back to `course.videos[0]`.
F7	**Unknown URLs silently go to the home page** LOW	`user-frontend/src/App.jsx:70`	There's no "page not found" page, so mistyped or old links look like the home page. **Fix:** add a simple 404 page with links.
F8	**Footer links incomplete** LOW	`user-frontend/src/components/Footer.jsx:159-162`	Quick Links has no "Courses" link, and "Login to Account" still shows after logging in. **Fix:** add Courses; show "My Dashboard" when logged in.
F9	**Tab titles don't change on some pages** LOW	`user-frontend/src/components/SiteSEO.jsx`	The course page tab says "E-Commerce Courses" instead of the course name. Login, payment, privacy and terms all show just "Sky Birds Solution". This hurts search results and bookmarks. **Fix:** set a title per page.
F10	**Admin thumbnails point to localhost** MEDIUM	`skybird-admin/src/pages/Courses.jsx:102`	Uploaded thumbnails load from `http://localhost:5000`, so they're broken images in the live admin panel. **Fix:** build the address from `VITE_API_URL`.
F11	**Admin login shows a blank page to logged-in admins** UPDATED LOW	`skybird-admin/src/pages/Login.jsx:14-18`	The redirect is commented out and the page returns nothing when you're logged in, so a logged-in admin opening `/login` sees a blank page. **Fix:** restore the redirect.

ID	Issue	Where	What goes wrong / Fix
F12	**Students who own a course can be sent to the buy page** NEW MEDIUM	`user-frontend/src/pages/Watch.jsx:171` `context/UserContext.jsx:56-73`	The watch page checks ownership as soon as the course loads, using the purchase list saved in the browser. The fresh list from the server may still be loading. If the saved list is out of date (bought on another device, or access granted later by the C3 webhook), the student is redirected to "Buy & unlock". **Fix:** wait for the purchase list to finish loading before deciding, or let the playback API's 403 decide.
F13	**A lesson-style video is publicly downloadable** NEW MEDIUM	`user-frontend/public/assets/Mod_1_Part_1_Enhanced.mp4` `src/pages/Home.jsx:642` `src/components/HomeVideo.jsx:13`	A 17.6 MB video named like a course module sits in the public folder and plays on the home page. Anyone can download it directly. If it's paid content rather than a free preview, it bypasses the HLS protection. `public/assets` is 68 MB in total, with both a PNG and a WebP copy of every logo. **Fix:** confirm it's meant to be a free preview; if not, replace it with a short trailer. Delete the unused PNG copies.
F14	**Admin panel deployment settings** NEW LOW	`skybird-admin/ (no vercel.json)` `skybird-admin/src/api/axios.js:4`	The admin app has no single-page-app rewrite config (the user site has `vercel.json`), so refreshing a page like `/courses` may return 404 depending on the host. Its API address also falls back to `localhost` if `VITE_API_URL` isn't set at build time (same cause as F10). **Fix:** add the same `vercel.json` rewrite (or the host's equivalent) and a `.env.production`.

4. Visual / UI issues

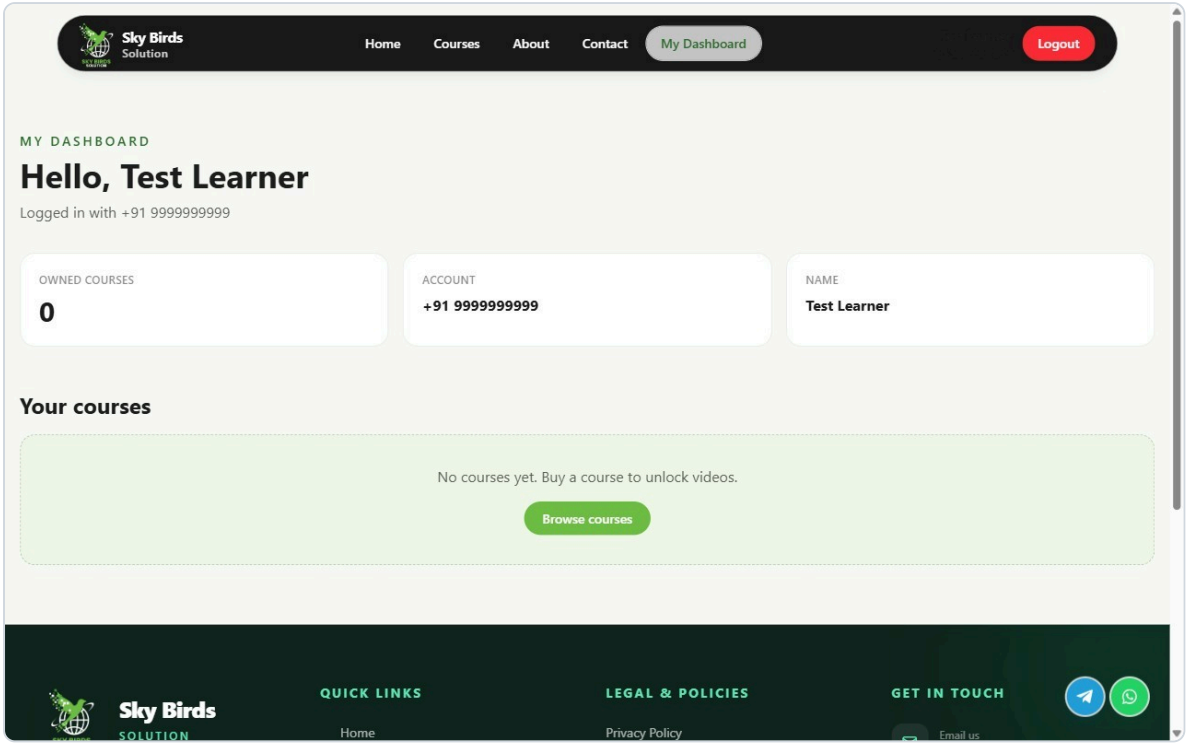
ID	Issue	Where	What goes wrong / Fix
V1	**Logged-in name in the navbar almost invisible** MEDIUM	`user-frontend/src/components/Navbar.jsx:93-97`	The user's name and mobile number use dark text (`text-ink`) on the black navbar (screenshot in section 5, top right). **Fix:** use `text-white` / `text-white/70`.
V2	**Floating buttons cover the mobile menu** LOW	`user-frontend/src/components/FloatingContactButtons.jsx`	The Telegram and WhatsApp buttons (`z-[1000]`) sit on top of the open mobile menu (`z-[70]`) and cover its footer and Login button area. **Fix:** lower their z-index below the drawer, or hide them while the menu is open.
V3	**Course card text** LOW	`user-frontend/src/components/CourseCard.jsx`	The card says "11 Lesson" instead of "11 Lessons", and the 5-star rating is hardcoded rather than coming from real reviews. **Fix:** pluralise the label; remove the stars or use real ratings.
V4	**Courses page promises courses that don't exist** LOW	`user-frontend/src/pages/Courses.jsx`	The page mentions Amazon, Meesho and Flipkart courses, but only one Amazon course exists. **Fix:** update the text, or hide it until those courses exist.

ID	Issue	Where	What goes wrong / Fix
V5	**Stray quote marks in the payment window** NEW LOW	`user-frontend/src/components/PaymentModal.jsx:292-295`	The note "Pay securely with UPI, cards, net banking…" is shown with literal quote marks around it. **Fix:** remove the quote characters from the text.

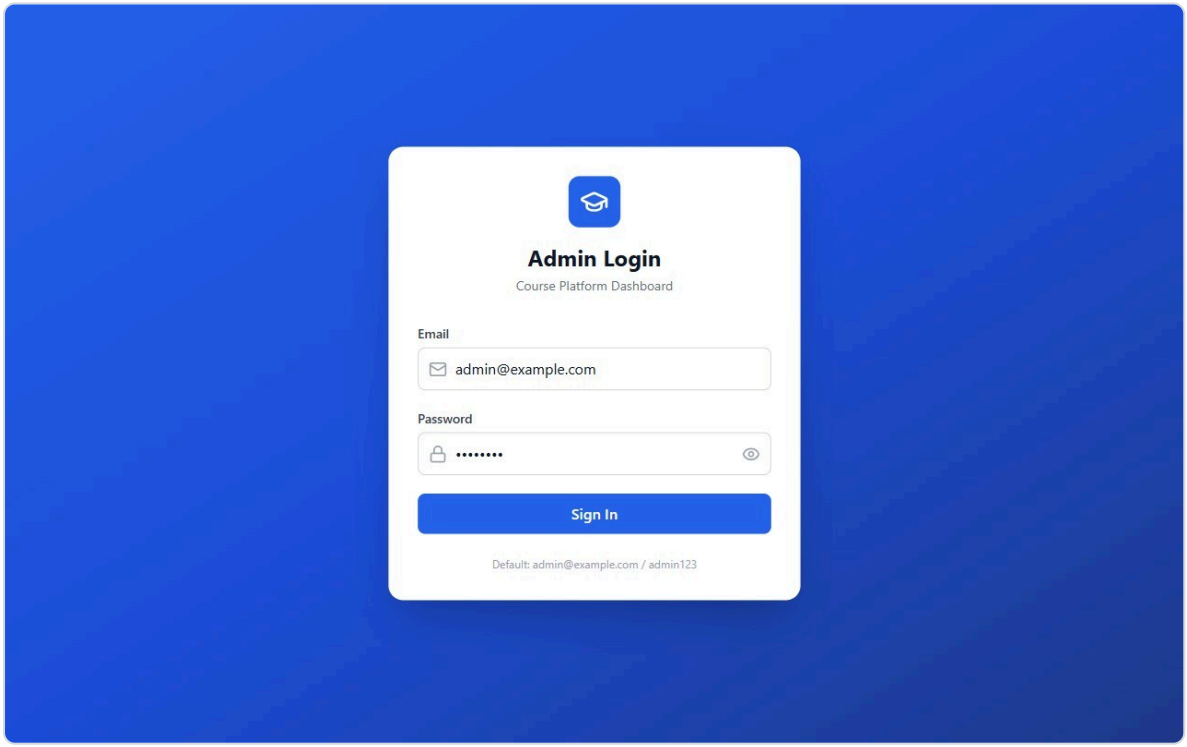
Minor / clean-up

ID	Issue	Where	What goes wrong / Fix
M1	**React error on every page**	`user-frontend/src/components/HomeVideo.jsx:274`	`<style jsx>` is Next.js syntax; in Vite it logs an error in the console. **Fix:** move those styles to `index.css`.
M2	**Site content fetched up to 7 times**	`Home, Footer, SiteSEO, Contact, About, PrivacyPolicy, Terms`	Each component calls `/api/site` on its own; SiteSEO calls it again on every page change. **Fix:** load it once in a shared context.
M3	**Unused frontend files** UPDATED	`src/components/Home/*` `src/components/About/*` `Services.jsx, App.css`	About 10 components and pages are never used (sd.jsx, AboutSection, ResourcesSection, Hero1, About1, StoryMissionSection, TeamPurposeSection, AnimatedNumber, Services, App.css). **Update:** `Hero1` is still imported in `Home.jsx:27` (only its use is commented out), so remove that import too. **Fix:** delete them.

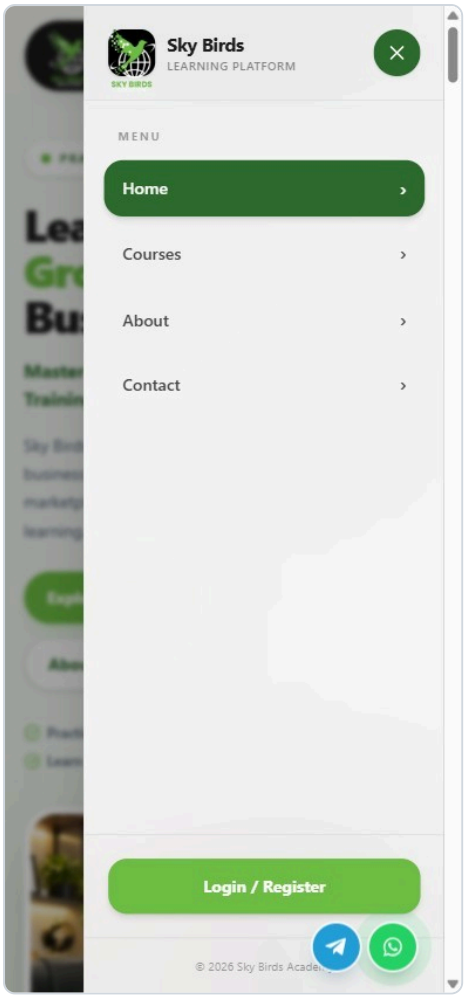
5. Screenshots



F1, F2, V1: the session token was rejected and cleared, yet the site still shows the user as logged in and the dashboard says "No courses yet". The name and number at the top right are almost invisible on the black navbar.



C4: the admin login is pre-filled and tells everyone the default credentials.



V2: the floating Telegram and WhatsApp buttons cover the bottom of the open mobile menu.

6. What was checked

Working correctly: all 14 user routes load; no broken images, empty links or "undefined" text; login-only pages redirect to `/login`; the mobile menu opens and closes; no sideways scrolling on a 390px phone; the admin sidebar links match its routes.

Second review (29 October 2026): every controller, route, model and service in the API, and the auth, payment, video and routing code in both frontends, was re-read line by line. All code-level findings from the first review were confirmed. The repository copy used for this review has no `.env` file and no `private-videos` folder, so C2, C7, B7 and B10 were checked against the code only.

Not tested (would need a real account, payment or SMS against the live database): real login and OTP, a real Razorpay payment, playing a purchased lesson end to end, submitting the contact form, admin pages behind the login, and the live hosting setup. No lint, build or dependency audit was run.